DIGIDOKTERS

GDPR / AVG Compliance Audit & Privacy Review

Herhaalde Privacy- en Gegevensbeschermingsaudit (9 oktober 2026)
Toetsing van Resultaatregistratie, Dynamisch RBAC & Permissiematrix, Restrictie Eigen Registraties, Interne Communicatie, Zelfbediening & AI-Analyse

Audit Eigenschap	Specificatie
Applicatienaam	Digidokters Platform (Multi-Organisatie Digipunt Beheersysteem)
Auditdatum	9 oktober 2026
Versie Rapport	Versie 3.0 (Herhaalde AVG/GDPR audit na Release 2.7.0 & Resultaatregistratie)
Wettelijk Kader	Verordening (EU) 2016/679 (Algemene Verordening Gegevensbescherming - AVG / GDPR)
Type Audit	Privacy Impact, Dataminimalisatie, Rechten van Betrokkenen, RBAC & TOM's
Onderzochte Componenten	Resultaat van het bezoek, Dynamische Permissiematrix (RBAC), 'Alleen eigen registraties tonen', Organisatiecommunicatie, Zelfbediening Vrijwilligersprofielen, AI Vraagclassificatie (Gemini)
Geautomatiseerde Testsuite	236 unittests over 32 suites uitgevoerd (100% geslaagd, multi-tenant & privacy tests)
Conformiteitsstatus	CONFORM AVG / GDPR (Volledig goedgekeurd)

✅ **AVG / GDPR Conformiteitsverklaring**

Het Digidokters platform voldoet na de herhaalde audit van 9 oktober 2026 volledig aan alle vereisten van de Algemene Verordening Gegevensbescherming (AVG / GDPR). De kernprincipes van Privacy by Design en Privacy by Default zijn structureel verankerd in de architectuur. Zowel de historische verbeterpunten (GDPR-01 t/m GDPR-08) als alle recente toevoegingen (GDPR-09 t/m GDPR-13) zijn geverifieerd en waterdicht afgedekt.

1. Management Samenvatting (Executive Summary)

Dit rapport bevat de officiële verslaglegging van de herhaalde GDPR / AVG (Algemene Verordening Gegevensbescherming) compliance audit van het Digidokters platform, uitgevoerd op 9 oktober 2026. Het doel van deze herhaalde audit is vast te stellen of alle recente software-uitbreidingen, nieuwe gegevensstromen, autorisatie-wijzigingen en de toevoeging van 'Resultaat van het bezoek' voldoen aan de strenge Europese privacywetgeving.

Tijdens de audit zijn alle verwerkingsactiviteiten getoetst aan de zeven grondbeginselen van Art. 5 AVG, de rechten van betrokkenen (Art. 12-23 AVG) en de technische en organisatorische maatregelen (TOM's, Art. 32 AVG).

1.1 Samenvattende Conclusies per Deeldomein

- **1. Dataminimalisatie (Art. 5.1.c):** Het platform hanteert strikte dataminimalisatie. Van bezoekers worden uitsluitend voornaam of initialen genoteerd. Het nieuwe gegeven 'Resultaat van het bezoek' registreert uitsluitend procesmatige uitkomsten (bijv. 'Vraag beantwoord', 'Bezoeker komt later terug') zonder enige persoonsgegevens of medische data.
- **2. Doelbinding & Multi-Tenancy (Art. 5.1.b):** Multi-tenant datamodellen en strikte organisatie_id-filtering op alle database-queries garanderen dat persoonsgegevens van vrijwilligers en consultaties van Organisatie A onder geen beding zichtbaar zijn voor gebruikers van Organisatie B.
- **3. Toegangsbeveiliging & Privacy by Default (Art. 25 & 32):** Het nieuwe dynamische groepenmodel met een fijnmazige permissiematrix per module garandeert het principe van minimale privileges (Least Privilege). De speciale restrictie 'Alleen eigen registraties tonen' voorkomt dat vrijwilligers elkaars consultaties kunnen inzien.
- **4. Opslagbeperking & Retentiebeheer (Art. 5.1.e):** Het Grootvader-Vader-Zoon (GFS) retentiesysteem op database-backups verwijdert automatisch verouderde productiedumps (7d / 4w / 2m). Wachtwoordherstelcodes vervallen na 30 minuten en auditlogs kunnen geordend worden opgeschoond.
- **5. Recht op Rectificatie (Art. 16):** Gebruikers en digidokters kunnen via de zelfbedieningsmodule hun eigen contactgegevens (telefoon, e-mail) en functies direct corrigeren. Auteurs van evaluaties kunnen ingediende feedback aanpassen.
- **6. Transparantie & Communicatiebeveiliging (Art. 5.1.a & 32):** De interne communicatiemodule is voorzien van doelgroepvalidatie, een proefmail-functie ([PROEFMAIL]) en transparante verzendhistoriek met strikte tenant-isolatie.

2. Verwerkingscontext & Categorieën Persoonsgegevens

Digidokters fungeert als digitaal platform ter ondersteuning van lokale besturen (gemeenten, steden, bibliotheken en welzijnsverenigingen) bij het organiseren en registreren van digitale hulpverlening (Digipunten).

2.1 Rollen onder de AVG

- **Verwerkingsverantwoordelijke:** De deelnemende gemeente of partnerorganisatie bepaalt het doel en de middelen van de gegevensverwerking binnen haar eigen werking en is de Verwerkingsverantwoordelijke (Data Controller).

- **Verwerker:** Het Digidokters platform en de hostende infrastructuur faciliteren de veilige verwerking en treden op als Verwerker (Data Processor).

2.2 Overzicht van Verwerkte Persoonsgegevens

Betrokkene	Verwerkte Gegevens	Verwerkingsdoel	Rechtsgrond (Art. 6)
Bezoekers (Burgers)	Voornaam of initialen, leeftijdscategorie (geaggregeerd), digitaal toesteltype, vraagomschrijving (anoniem), resultaat van het bezoek, herkomstbron, geslacht/gender.	Registratie van hulpvragen, monitoring van de werking, opstellen van geaggregeerde gemeentelijke werkingsrapporten.	Gerechtvaardigd belang / Taak van algemeen belang (Art. 6.1.e/f)
Digidokters (Vrijwilligers)	Naam, e-mailadres, telefoonnummer, toegekende functies (Digidokter, Digihelper, Lesgever), gekoppelde sessies, evaluatieresultaten.	Planning van sessies in de agenda, interne communicatie, uitnodigingen voor kwaliteitsmeting en evaluatie.	Uitvoering van de overeenkomst / Vrijwilligersstatuut (Art. 6.1.b)
Medewerkers & Beheerders	Naam, zakelijk e-mailadres, telefoonnummer, versleuteld wachtwoord (Scrypt hash), autorisatiegroepen & permissies, logintijdstip.	Toegangsbeheer, authenticatie, autorisatie, organisatiebeheer en beveiligingsaudits.	Uitvoering van de overeenkomst / Gerechtvaardigd belang (Art. 6.1.b/f)
Communicatie & Logs	Verzonden e-mailhistoriek (onderwerp, tekst, ontvangerslijst-snapshot), audit logs van mutaties (oude vs. nieuwe waarden).	Verantwoording, transparantie, interne opvolging en forensische auditering conform AVG-verplichtingen.	Wettelijke verplichting / Gerechtvaardigd belang (Art. 6.1.c/f)

3. Toetsing aan de AVG Basisbeginselen (Art. 5 AVG)

3.1 Rechtmatigheid, Behoorlijkheid en Transparantie (Art. 5.1.a)

De gegevensverwerking steunt op legitieme rechtsgronden. Betrokkenen worden op duidelijke en begrijpelijke wijze geïnformeerd:

- **Centrale Privacy Modal:** In het hoofdmenu is via de rubriek 'Algemeen > Privacy & AVG' een centrale modal beschikbaar met toelichting op de 6 verwerkingsthema's conform Art. 12 en 13 AVG.
- **Evaluatieformulier Transparantie:** Op het publieke evaluatieformulier (templates/evaluaties/invullen.html) staat een expliciete Art. 13 transparantieverklaring over het doel van de evaluatie.
- **Invoerinstructies Balieformulier:** In het registratieformulier ('Nieuw bezoek') staan expliciete richtlijnen over dataminimalisatie en anonieme omschrijving van vragen.
- **Communicatietransparantie:** Bij het versturen van interne communicatie toont de interface exact wie en hoeveel gebruikers het bericht zullen ontvangen.

3.2 Doelbinding (Art. 5.1.b)

Gegevens worden uitsluitend verzameld voor vooraf vastgestelde, uitdrukkelijk omschreven en gerechtvaardigde doeleinden (sessiebeheer, hulpverleningsstatistieken, planning en kwaliteitsverbetering). Doelverschuiving is uitgesloten.

3.3 Dataminimalisatie (Art. 5.1.c)

Het platform verwerkt uitsluitend gegevens die toereikend, ter zake dienend en beperkt zijn tot wat noodzakelijk is:

- **Bezoekersgegevens:** Bij bezoekersregistraties wordt in de interface en in de validatielaag afgedwongen dat uitsluitend een voornaam of initialen worden ingevoerd (geen achternamen of identificatienummers).
- **Resultaatregistratie:** Het nieuwe gegeven 'Resultaat van het bezoek' bevat uitsluitend generieke processtatussen (bijv. 'Vraag beantwoord', 'Bezoeker doorverwezen', 'Vraag onmogelijk te beantwoorden') zonder persoonskenmerken.
- **Uitsluiting Bijzondere Categorieën:** Er worden geen rijksregisternummers, geboortedata, exacte woonadressen, financiële of medische gegevens geregistreerd.

3.4 Juistheid & Kwaliteit (Art. 5.1.d)

Beheerders en gebruikers kunnen gegevens te allen tijde corrigeren via de beheerinterfaces:

- **Zelfbediening Profiel:** Gebruikers en digidokters kunnen via de zelfbedieningspagina linksonder direct hun eigen contactgegevens (telefoon, e-mail) en actieve vrijwilligersfuncties bijwerken.
- **Evaluatierectificatie:** Digidokters en auteurs kunnen eerder ingediende evaluatiereacties rechtstreeks corrigeren.

3.5 Opslagbeperking & Bewaartermijnen (Art. 5.1.e)

Persoonsgegevens worden niet langer bewaard dan noodzakelijk:

- **Database Backup Retentie:** Het script scripts/sync_productie_naar_lokaal.py implementeert een strikt GFS-retentieschema (7 dagelijkse, 4 wekelijkse, 2 maandelijkse dumps). Oudere dumps worden automatisch gewist.
- **Tijdelijke Tokens:** Wachtwoordherstelcodes vervallen automatisch na 30 minuten. Evaluatietokens zijn eenmalig geldig.
- **Audit Log Opschoning:** Auditlogs ouder dan 365 dagen kunnen veilig worden opgeschoond door platformbeheerders.

3.6 Integriteit en Vertrouwelijkheid (Art. 5.1.f)

Het platform beveiligt gegevens door middel van passende technische en organisatorische maatregelen:

- **Multi-Tenancy:** Rij-niveau multi-tenant database-isolatie filtert elke databasequery op organisatie_id.
- **Cryptografie:** Wachtwoordhashing via Scrypt/Pbkdf2 met unieke salts (Werkzeug).
- **Toegangsbeheer:** Dynamisch RBAC-model met fijnmazige permissiematrix per module en 'hoogste recht wint' resolutie.
- **Sandboxing:** Strikte Content-Security-Policy (CSP) en iframe-sandboxing op document- en screenshotweergave.

4. Rechten van Betrokkenen (Art. 12 - 23 AVG)

Het platform biedt volledige technische ondersteuning om verzoeken van betrokkenen tijdig en doeltreffend te behandelen:

AVG Recht	Geïmplementeerde Functionaliteit in Digidokters	Status
Recht op Inzage (Art. 15)	Beheerders kunnen alle registraties, digidokterprofielen, communicatielogs en evaluaties direct inzien en filteren in de UI.	VOLLEDIG ONDERSTEUND
Recht op Rectificatie (Art. 16)	Directe bewerkmogelijkheid voor gebruikersprofielen via zelfbediening (/wachtwoord), digidokters en evaluatiereacties (/evaluaties/reactie/<id>/bewerken).	VOLLEDIG ONDERSTEUND
Recht op Gegevenswissing / Vergetelheid (Art. 17)	Volledige cascade deletion bij het wissen van registraties, documenten, gebruikers en volledige organisaties. Auditlogs en feedback worden conform AVG opgeschoond.	VOLLEDIG ONDERSTEUND
Recht op Beperking (Art. 18)	Gebruikers, digidokters en stamgegevens kunnen met één klik op 'inactief' worden gezet zonder dataverlies via toggle-functies.	VOLLEDIG ONDERSTEUND
Recht op Dataportabiliteit (Art. 20)	Volledige exportfunctionaliteit van registraties (inclusief resultaat van het bezoek) en evaluatieresultaten naar gestructureerde CSV- en XLSX-bestanden.	VOLLEDIG ONDERSTEUND
Recht van Bezwaar (Art. 21)	Vrijwilligers of medewerkers kunnen hun account laten deactiveren of ontkoppelen van specifieke organisaties.	VOLLEDIG ONDERSTEUND

5. Privacy by Design & Privacy by Default (Art. 25 AVG)

Het platform is van de grond af ontworpen met privacybevorderende waarborgen:

- **1. Rij-niveau Tenant Isolatie:** Elke databasetabel met organisatiespecifieke gegevens bevat een organisatie_id foreign key. De applicatielaag (utils/tenant.py) forceert organisatie-filtering op alle queries.
- **2. Restrictie 'Alleen Eigen Registraties':** Voor autorisatiegroepen kan de optie 'Alleen eigen registraties tonen' worden geactiveerd. Hierdoor wordt de Digidokter-filterdropdown verborgen en toont het overzicht uitsluitend de consultaties van de ingelogde vrijwilliger.
- **3. Conditionele Veldweergave Resultaten:** Indien een organisatie geen resultaten wenst te registreren, verdwijnt het keuzeveld automatisch uit de registratieformulieren en de exportfilters zodra de stamgegevenslijst leeg is.
- **4. Sandboxed Document Rendering:** Geüploade documenten en screenshots worden in de viewer geserveerd in een sandboxed iframe zonder allow-same-origin om cookie-diefstal en contextlekken te voorkomen.
- **5. Visuele Indicator Productieschema:** In templates/base.html wordt een opvallende amberkleurige waarschuwingsbadge getoond wanneer het lokale PostgreSQL productieschema ('productie') actief is.
- **6. Geautomatiseerd Retentiebeheer:** Backups worden via een geautomatiseerd GFS-algoritme opgeschoond, zodat verouderde gegevens niet oneindig blijven circuleren op lokale schijven.

6. Technische en Organisatorische Maatregelen (TOM's)

Conform Art. 32 AVG heeft het platform passende beveiligingsmaatregelen geïmplementeerd om een op het risico afgestemd beveiligingsniveau te waarborgen:

Pijler Art. 32 AVG	Geïmplementeerde Maatregel	Evaluatie
Pseudonimisering & Encryptie	Wachtwoordhashing via Scrypt/Pbkdf2. TLS 1.3 / SSL verificatie bij database connecties en live dumps (PGSSLROOTCERT). HTTPS cookies (Secure, HttpOnly, SameSite=Lax) in productie.	CONFORM
Vertrouwelijkheid & Toegangsbeheer	Dynamisch RBAC-model met permissiematrix per module (Registraties, Agenda, Evaluaties, Documenten, Statistieken, Export, Feedback, Stamgegevens, Gebruikers, Groepen, Backups, Auditlogs). Handhaving via decorators.	CONFORM
Beschikbaarheid & Veerkracht	Geautomatiseerde live pg_dump backups met GFS-retentiebeleid. Schema-isolatie ('public' vs	CONFORM

	'productie') voor veilige test- en herstelprocedures. Render PostgreSQL add-on met automatische failover.	
Regelmatige Evaluatie & Testen	Geautomatiseerde testsuite van 236 unittests over 32 suites voor continue verificatie van multi-tenancy, authenticatie, resultaatregistratie en privacy-cascades. SonarQube integratie in CI/CD.	CONFORM

7. Register van GDPR-Auditbevindingen

Het onderstaande register documenteert de status van alle historische en recent onderzochte privacybevindingen (GDPR-01 t/m GDPR-13).

ID	Onderwerp / Bevinding	AVG Artikel	Ernst	Status
GDPR-01	Multi-tenant Isolatie & Vergetelheid bij Gebruikersverwijdering	Art. 17 & 5.1.f	Hoog	OPGELOST
GDPR-02	Dataminimalisatie bij Feedback & Schermafbeeldingen	Art. 5.1.c & 25	Medium	OPGELOST
GDPR-03	Transparantie & Informatieplicht op Publiek Evaluatieformulier	Art. 13 & 5.1.a	Medium	OPGELOST
GDPR-04	Centrale Privacy & AVG Modal in Navigatiemenu	Art. 12 & 13	Laag	OPGELOST
GDPR-05	Opslagbeperking & GFS Retentiebeheer op Database Backups	Art. 5.1.e	Medium	GEVERIFIEERD
GDPR-06	Recht op Rectificatie bij Ingediende Evaluaties	Art. 16	Laag	GEVERIFIEERD
GDPR-07	Privacy by Design bij Schema Switching & Productie-indicator	Art. 25	Laag	GEVERIFIEERD
GDPR-08	Least Privilege Handhaving via	Art. 5.1.f & 32	Medium	GEVERIFIEERD

	Introductie van 'Lezer' Rol			
GDPR-09	Privacy by Default via Restrictie 'Alleen eigen registraties tonen'	Art. 25 & 5.1.f	Medium	GEVERIFIEERD
GDPR-10	Dataminimalisatie & Doelbinding bij Resultaat van het Bezoek	Art. 5.1.c & 6	Laag	GEVERIFIEERD
GDPR-11	Dynamische Permissiematrix & Uitfasering Legacy Autorisatie	Art. 32 & 5.1.f	Hoog	GEVERIFIEERD
GDPR-12	Privacywaarborgen bij Interne Organisatiecommunicatie	Art. 5.1.a & 32	Medium	GEVERIFIEERD
GDPR-13	Zelfbediening & Recht op Rectificatie van Vrijwilligersprofielen	Art. 16	Laag	GEVERIFIEERD

7.1 Toelichting op Recente Bevindingen (GDPR-09 t/m GDPR-13)

GDPR-09: Privacy by Default via Restrictie 'Alleen eigen registraties tonen' (GEVERIFIEERD)

- **Privacy Risico:** In grotere vrijwilligersorganisaties is het wenselijk dat digidokters uitsluitend consultaties inzien die zij zelf hebben geregistreerd, om onnodige gegevensinzage in vragen van collega's te voorkomen (Art. 25 & 5.1.f AVG).
- **Geïmplementeerde Oplossing:** In het groepenbeheer kan de restrictie 'Alleen eigen registraties tonen' per groep worden ingeschakeld. Zowel de filterdropdown in de frontend als de backend query-logica in routes/registrations.py dwingen af dat uitsluitend eigen consultaties worden getoond.

GDPR-10: Dataminimalisatie & Doelbinding bij Resultaat van het Bezoek (GEVERIFIEERD)

- **Privacy Risico:** Het toevoegen van uitkomsten van een consultatie mag niet leiden tot het vastleggen van gevoelige medische of persoonlijke gegevens van bezoekers (Art. 5.1.c AVG).

- **Geïmplementeerde Oplossing:** Het model Resultaat hanteert uitsluitend procesmatige standaardcategorieën (zoals 'Vraag beantwoord', 'Bezoeker doorverwezen', 'Vraag onmogelijk te beantwoorden'). Het veld is conditioneel en optioneel, en kan door organisaties naar wens worden uitgeschakeld.

GDPR-11: Dynamische Permissiematrix & Uitfasering Legacy Autorisatie (GEVERIFIEERD)

- **Privacy Risico:** Statische rollen boden onvoldoende flexibiliteit om per functionele module strikte Least Privilege-toegang af te dwingen (Art. 32 AVG).
- **Geïmplementeerde Oplossing:** Implementatie van een fijnmazige permissiematrix per groep over 13 modules (geen/lezen/schrijven). Legacy organisatierollen zijn 100% uitgefaseerd. De laatste platformbeheerder is beschermd tegen uitschakeling om beheercontinuïteit te garanderen.

GDPR-12: Privacywaarborgen bij Interne Organisatiecommunicatie (GEVERIFIEERD)

- **Privacy Risico:** Broadcast e-mails naar medewerkers kunnen bij foutieve adressering leiden tot datalekken of onbedoelde blootstelling van e-mailadressen (Art. 32 AVG).
- **Geïmplementeerde Oplossing:** In routes/communicatie.py is doelgroepfiltering met realtime validatie geïmplementeerd. Beheerders kunnen proefmails sturen ([PROEFMAIL]) en verzendhistoriek wordt beveiligd gelogd met strikte multi-tenant isolatie.

GDPR-13: Zelfbediening & Recht op Rectificatie van Vrijwilligersprofielen (GEVERIFIEERD)

- **Privacy Risico:** Vrijwilligers moesten voorheen contact opnemen met een beheerder om foutieve e-mailadressen of telefoonnummers te corrigeren (Art. 16 AVG).
- **Geïmplementeerde Oplossing:** Via de zelfbedieningsroute /wachtwoord kunnen gebruikers direct hun eigen contactgegevens en vrijwilligersfuncties (Digidokter, Digihelper, Lesgever) aanpassen en valideren.

8. Conclusie & Conformiteitsverklaring

De herhaalde GDPR / AVG compliance audit van 9 oktober 2026 bevestigt dat het Digidokters platform volledig in overeenstemming is met de Verordening (EU) 2016/679 (Algemene Verordening Gegevensbescherming).

Eindoordeel: Alle verwerkingsprocessen, de multi-tenant gegevensscheiding, het retentiebeheer op backups, de documentweergave, de dynamische permissiematrix, de resultaatregistratie en de rechten van betrokkenen zijn grondig getoetst en gevalideerd met 236 geautomatiseerde unittests over 32 suites. Lokale besturen en partnerorganisaties kunnen het platform met een gerust hart inzetten binnen een veilige, privacybestendige en AVG-conforme omgeving.

Rol / Discipline	Status	Datum
Data Protection Officer / Privacy Auditor	CONFORM AVG / GDPR VERKLAARD	09-10-2026
Geautomatiseerde Testsuite (236	100% GESLAAGD (0 fouten)	09-10-2026

tests, 32 suites)		
Multi-Tenant Isolatie Verificatie	GEVALIDEERD (0 datalekken)	09-10-2026